

Pruebas de Integración, SAST y DAST en el Pipeline DevSecOps

Ecosistema Multicapa Zero-Trust Logístico y Anti-Spoofing
Program Manager: Ing. Scarlett Alejandra Cisneros Aymerich

1. Estrategia de Pruebas Automatizadas de Seguridad

El ciclo de vida del desarrollo seguro (*DevSecOps*) integra de forma automatizada fases de validación continua para asegurar que tanto el código fuente de los microservicios como el hardware Edge AI cumplan con los más altos estándares de robustez antes de llegar a producción [cite: 5, 12].

2. Análisis Estático de Código (SAST) y SCA

Tipo de Análisis	Herramienta Utilizada	Objetivo e Implementación
SAST (Static Application Security Testing)	SonarQube [cite: 16]	Inspección profunda del código fuente y del SDK en busca de vulnerabilidades lógicas, fallas de inyección y malas prácticas de programación antes de la compilación.
SCA (Software Composition Analysis)	Snyk [cite: 16]	Auditoría automatizada de bibliotecas de terceros y dependencias de código abierto para detectar vulnerabilidades conocidas (CVEs) en contenedores y microservicios.

3. Pruebas Dinámicas (DAST) y Simulación de Ataques RF

Evaluación en Entornos Aislados:

- **OWASP ZAP (DAST):** Ejecución de pruebas dinámicas sobre las APIs RESTful y pasarelas de microservicios desplegadas en Kubernetes Engine (GKE) para detectar fallas en tiempo de ejecución [cite: 14, 16].
- **Simulación SDR (Radio Definida por Software):** Pruebas físicas de laboratorio donde se emiten ondas de radiofrecuencia simulando ataques de *GPS Spoofing* e interferencias (*jammers*) para validar la respuesta del algoritmo Edge AI [cite: 14, 16].

4. Pruebas de Integración y Red P2P de Hashes

Validación del Sistema Distribuido:

- **Integración Multicapa:** Verificación de la comunicación segura entre el hardware físico (GNSS + IMU), la nube confidencial (Confidential VMs) y las interfaces de usuario o aliados (SDK / Google Maps Fleet Engine) [cite: 5, 12, 17].
- **Pruebas de Red P2P:** Simulación de nodos múltiples compartiendo cadenas criptográficas (hashes SHA-256) para evaluar la tolerancia a fallos, velocidad de propagación de alertas de pánico y resiliencia ante pérdida de conectividad central [cite: 17].